Day 27: MITRE ATT&CK Mapping Lab

Mapping the CyberAmy Repeated Authentication Failures to Credential Access / T1110.001

SOC Internship - TriosCyber

Field	Details
Intern Name	Amrita Pathak
Date	29 September 2026
Internship Track	SOC (Security Operations Center)
Assigned Task	Choose one simulated behavior from the lab, such as repeated authentication failures or suspicious process activity. Map it to the most relevant MITRE ATT&CK tactic/technique and record the supporting evidence. (Tools: MITRE ATT&CK, Wazuh/log evidence)
Status of this Report	**Practical mapping exercise based on real evidence. The behavior mapped is the controlled sequence of 8 failed logons generated in Day 25 and collected, hashed and sealed as case INC-20260929-001 in Day 26. Every ATT&CK ID, tactic, mitigation and detection reference in this report was checked against the live MITRE ATT&CK website (attack.mitre.org) on 29 September 2026, and every Wazuh rule against Wazuh's public ruleset. No Wazuh manager is deployed in this lab (see Days 17-20), so the Wazuh portion compares the real rule definitions against the real evidence rather than a live alert.**

Table of Contents

Table of Contents 2
Key Terms 3
Important Note on This Report 3
Executive Summary 4
1. Objective 5
2. How ATT&CK Is Structured 5
3. The Behavior Selected 5
4. Extracting the Evidence That Drives the Mapping 6
5. The Mapping 9
5.1 Tactic: Credential Access (TA0006) 9
5.2 Technique: Brute Force (T1110) 9
5.3 Sub-technique: Password Guessing (T1110.001) 9
5.4 Alternatives Considered and Rejected 10
6. How Wazuh Tags the Same Behavior 11
7. Detection and Mitigation Coverage 12
7.1 Detection 12
7.2 Mitigations 12
8. Supporting Evidence Record 14
9. Mapping Summary 16
10. Conclusion 16
References 17

Key Terms

- **MITRE ATT&CK:** A free, globally used knowledge base of real-world adversary behavior, maintained by MITRE. It gives defenders a shared vocabulary: instead of saying "someone kept trying passwords", an analyst says "T1110.001", and every SOC in the world understands exactly what was observed.
- **Tactic:** The adversary's goal at a given stage: the "why". Example: Credential Access (TA0006), meaning the adversary is trying to steal account names and passwords.
- **Technique:** How the adversary tries to reach that goal: the "how". Example: T1110 Brute Force.
- **Sub-technique:** A more specific variant of a technique. Example: T1110.001 Password Guessing, one of four ways to brute force.
- **Detection Strategy and Analytic:** ATT&CK's guidance on how a technique can be detected. For T1110.001 this is DET0551, which includes analytic AN1521 describing a series of Windows Event ID 4625 failures.
- **Mitigation:** A defensive control ATT&CK associates with a technique, such as M1036 Account Use Policies (for example, account lockout).
- **Mapping:** The act of matching observed evidence to the ATT&CK entry that best describes the behavior. A mapping describes what happened, not whether it was malicious.

Important Note on This Report

The behavior mapped here was a controlled, self-run lab test, and Day 25 and Day 26 already closed it as a benign true positive. ATT&CK mapping describes the behavior itself, not the intent behind it: 8 password guesses against one account is T1110.001 whether an attacker or an intern typed them. This report therefore maps the behavior exactly as a SOC would for a real alert, and states the benign verdict separately.

Executive Summary

The behavior chosen for mapping was the repeated authentication failure pattern from Day 25: 8 failed interactive logons against the local administrator account CyberAmy on DESKTOP-AUHDFVM between 13:07:33 and 13:11:19 IST, followed by a successful logon at 13:12:10. The evidence comes from the sealed Day 26 case, INC-20260929-001.

The behavior maps to the tactic Credential Access (TA0006), technique Brute Force (T1110), sub-technique Password Guessing (T1110.001). The deciding evidence is that many passwords were tried against a single account whose user name was valid (SubStatus 0xC000006A). The other three Brute Force sub-techniques were each considered and rejected on the evidence, as were two other techniques suggested by Wazuh's own rule tags.

The evidence also matches MITRE's own detection guidance for T1110.001 (analytic AN1521: a series of Event ID 4625 failures), and the lab already had one of MITRE's listed mitigations in place: an account lockout threshold of 10 (M1036 Account Use Policies).

1. Objective

Choose one simulated behavior from the lab, identify the MITRE ATT&CK tactic, technique and sub-technique that best describe it, justify the choice against the alternatives, and record the evidence supporting the mapping.

2. How ATT&CK Is Structured

For a beginner, the simplest way to read ATT&CK is as a set of questions, each more specific than the last:

Level	Question it answers	This lab's answer
Tactic	What was the adversary trying to achieve?	Credential Access (TA0006): obtain a working password
Technique	How were they trying to achieve it?	Brute Force (T1110): repeated attempts until one works
Sub-technique	Which specific variant?	Password Guessing (T1110.001): many passwords, one account
Evidence	What proves it?	8 x Event ID 4625, one account, one source, 226 seconds

A good mapping always goes down to the most specific level the evidence supports, and never further. Mapping only to T1110 would be correct but imprecise; guessing a sub-technique the evidence cannot support would be worse than stopping at T1110.

3. The Behavior Selected

Repeated authentication failures were chosen over suspicious process activity because this lab holds complete, verified, hash-sealed evidence for them (Day 26), whereas no process-activity evidence has been collected. Mapping should always start from evidence you can prove, not from the behavior that sounds most interesting.

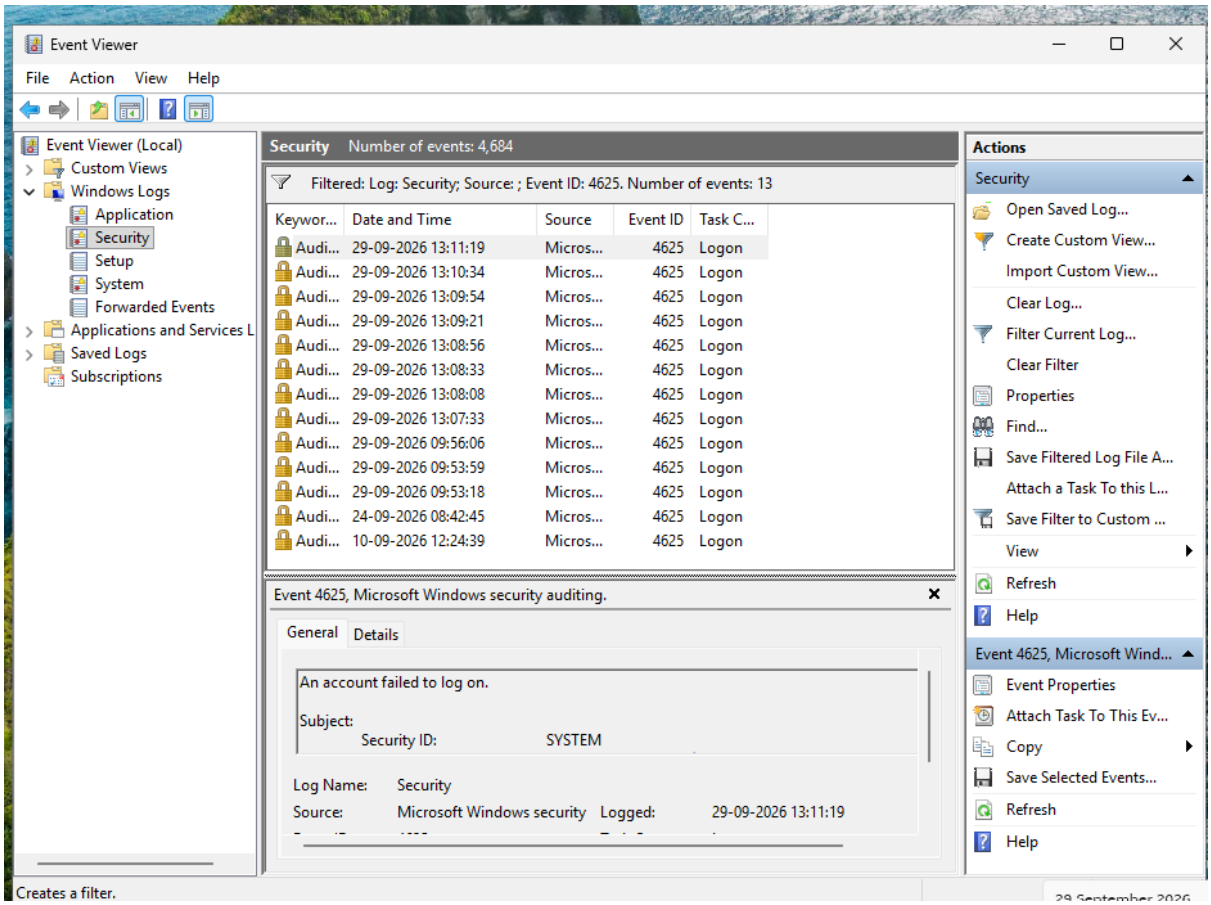


Figure 1. Event Viewer, Security log filtered to Event ID 4625 (case file SS02).

What this screenshot shows:

- The Security log is filtered to Event ID 4625, the Windows event for a failed logon.
- The eight entries from 13:07:33 to 13:11:19 on 29-09-2026 are the behavior being mapped. Entries further down are from earlier, unrelated sessions and are excluded by their timestamps.
- This is the raw on-screen view of the behavior; Figure 2 shows the same events extracted from the sealed evidence file with their key fields.

4. Extracting the Evidence That Drives the Mapping

The mapping depends on four facts, all taken from the exported log sealed in the Day 26 case. They were extracted with this command, which reads the evidence file rather than the live log:

```powershell
$case = "C:\Incidents\INC-20260929-001"
$rows = Get-WinEvent -Path "$case\02_Logs_Raw\Security_INC_window.evtx" |
  ForEach-Object {
    $x = [xml]$_.ToXml(); $d = @{}
    $x.Event.EventData.Data | ForEach-Object { $d[$_.Name] = $_.'#text' }
    [pscustomobject]@{
      TimeCreated = $_.TimeCreated.ToString("yyyy-MM-dd HH:mm:ss")
      EventID = $_.Id; TargetUser = $d['TargetUserName']
      LogonType = $d['LogonType']; SourceIP = $d['IpAddress']
      Workstation = $d['WorkstationName']
      Status = $d['Status']; SubStatus = $d['SubStatus']
    }
  } | Sort-Object TimeCreated
$rows | Format-Table -AutoSize
```

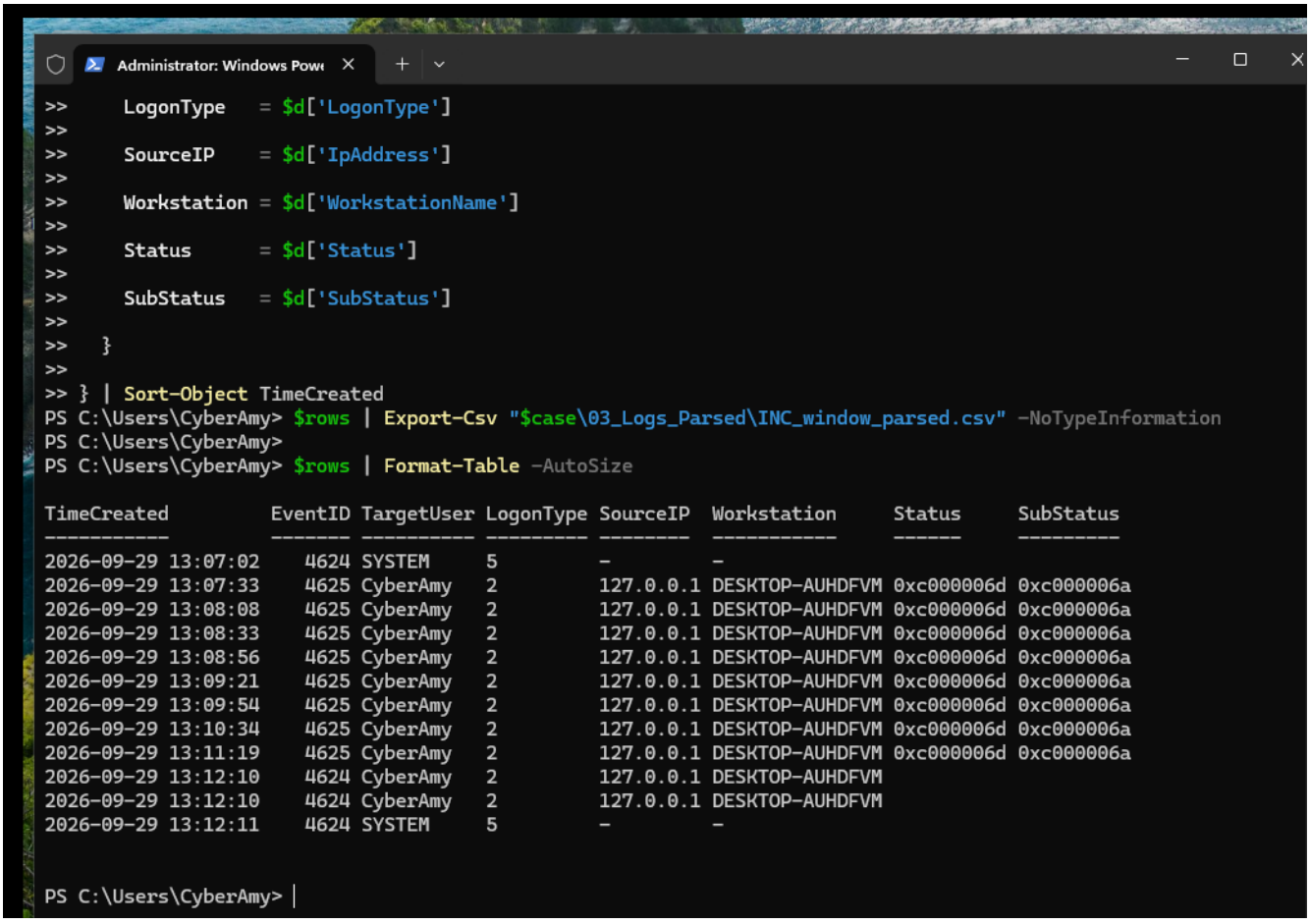


Figure 2. Key fields of every logon event in the incident window, read from the sealed evidence file (case file SS05).

What this screenshot shows:

- Eight 4625 rows for one account, CyberAmy: a single target, which is the defining feature of Password Guessing.
- SubStatus 0xc000006a on every failure: the user name was correct and the password was wrong. The attempts were aimed at a real, known account.
- Logon Type 2 with source IP 127.0.0.1 and workstation DESKTOP-AUHDFVM on every failure: all attempts came from one source, the machine's own console.
- Timestamps from 13:07:33 to 13:11:19: 8 attempts in 226 seconds, a repeated, iterative pattern rather than a single mistyped password. The two 13:12:10 rows are the successful logon; the SYSTEM rows are Windows services and are not part of the behavior.

Fact	Value	Why it matters for mapping
Number of failures	8	Repetition is what makes it brute force, not a typo
Accounts targeted	1 (CyberAmy)	One account, many passwords = Password Guessing
Failure reason	SubStatus 0xC000006A	Valid user name, wrong password
Source	127.0.0.1, Logon Type 2	Single source; online interactive attempts
Time span	226 seconds	Iterative attempts in a short window
Outcome	Success at 13:12:10	Relevant to whether Valid Accounts (T1078) also applies

5. The Mapping

5.1 Tactic: Credential Access (TA0006)

Repeatedly trying passwords has one purpose: to end up holding a working credential. That is the definition of the Credential Access tactic, and it is the only tactic MITRE assigns to T1110.

5.2 Technique: Brute Force (T1110)

MITRE's description of T1110 begins: "Adversaries may use brute force techniques to gain access to accounts when passwords are unknown or when password hashes are obtained. Without knowledge of the password for an account or set of accounts, an adversary may systematically guess the password using a repetitive or iterative mechanism." Eight consecutive password attempts against one account in under four minutes is exactly that repetitive mechanism. T1110 has four sub-techniques, so the next question is which one the evidence supports.

5.3 Sub-technique: Password Guessing (T1110.001)

MITRE's page for T1110.001, captured during this lab, is shown below:

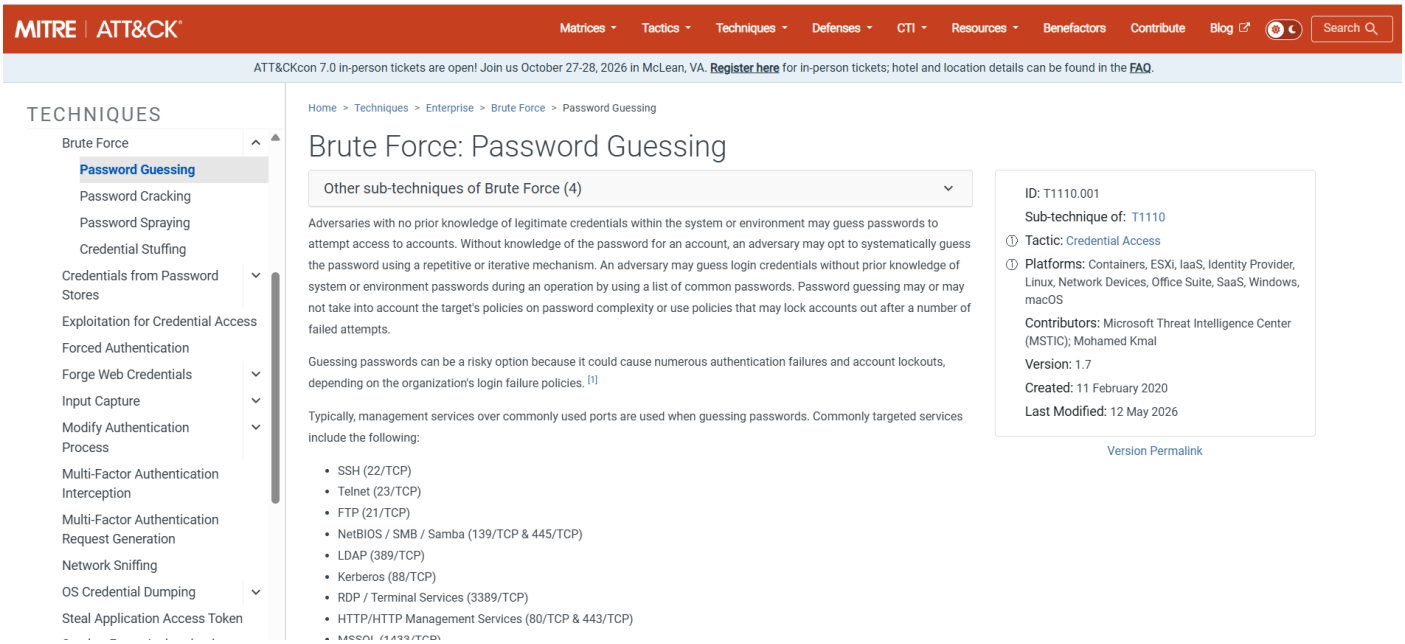


Figure 3. The MITRE ATT&CK page for T1110.001 Brute Force: Password Guessing, captured on 29 September 2026.

What this screenshot shows:

- The breadcrumb at the top (Home > Techniques > Enterprise > Brute Force > Password Guessing) and the left-hand menu show where this entry sits: it is one of the four sub-techniques listed under Brute Force (Password Guessing, Password Cracking, Password Spraying, Credential Stuffing).

- The information panel on the right confirms the identifiers used in this report: ID T1110.001, sub-technique of T1110, tactic Credential Access, with Windows among its platforms. The entry is version 1.7, created 11 February 2020 and last modified 12 May 2026, so this report is mapped against the current version.
- The description reads: "Adversaries with no prior knowledge of legitimate credentials within the system or environment may guess passwords to attempt access to accounts. Without knowledge of the password for an account, an adversary may opt to systematically guess the password using a repetitive or iterative mechanism." This matches the evidence: the password was unknown to whoever typed the attempts, and it was guessed repeatedly.
- The second paragraph notes that guessing "could cause numerous authentication failures and account lockouts". The numerous failures are exactly the 8 Event ID 4625 records in this case, and the lockout risk is why the lockout policy was checked before testing in Day 25.
- The list of commonly targeted services includes RDP (3389/TCP) and SMB (445/TCP). These attempts were made at the local console instead (Logon Type 2), which the sub-technique still covers, since it describes the guessing behavior regardless of which logon interface is used.

The evidence matches each part of this definition: an unknown password, repeated guesses, a single target account, and the resulting authentication failures.

5.4 Alternatives Considered and Rejected

A mapping is only as strong as the reasons for rejecting the alternatives. Each was tested against the evidence:

Candidate	What it means	Verdict and reason
T1110.002 Password Cracking	Recovering passwords offline from stolen password hashes	Rejected: MITRE describes cracking as recovering plaintext passwords from already-obtained password hashes. That happens offline and generates no failed logons on the target, whereas every attempt here was a live logon recorded as Event ID 4625
T1110.003 Password Spraying	One or a few common passwords tried against many different accounts	Rejected: only one account was targeted
T1110.004 Credential Stuffing	Using credentials obtained from breach dumps of	Rejected: nothing in the evidence indicates breached credential pairs; one account was tried repeatedly with different passwords

	unrelated accounts, relying on password reuse	
T1078 Valid Accounts (T1078.003 Local Accounts)	An adversary logging on with a legitimate account's real credentials	Not applied: the 13:12:10 success was the account owner. In a real incident where the successful logon was the attacker, T1078.003 would be added as a follow-on technique
T1531 Account Access Removal	Impact: locking, deleting or changing accounts to deny legitimate users access	Not applied: the lockout threshold of 10 was never reached and the account was never locked (Section 7)

6. How Wazuh Tags the Same Behavior

Wazuh attaches ATT&CK IDs to its own rules, so it is worth checking what a live deployment would have tagged. The three rules that apply to this evidence were read directly from Wazuh's public ruleset (0580-win-security_rules.xml). Only the parts relevant to mapping are shown:

```
<rule id="60105" level="5">
  <description>Windows Logon Failure</description>
  <mitre><id>T1078</id></mitre>
</rule>

<rule id="60122" level="5">
  <if_sid>60105</if_sid>
  <description>Logon Failure - Unknown user or bad password</description>
  <mitre><id>T1531</id></mitre>
</rule>

<rule id="60204" level="10" frequency="$MS_FREQ" timeframe="240">
  <if_matched_group>authentication_failed</if_matched_group>
  <same_field>win.eventdata.ipAddress</same_field>
  <description>Multiple Windows Logon Failures</description>
  <mitre><id>T1110</id></mitre>
</rule>
```

Rule	Fires on	Wazuh's ATT&CK tag	Analyst assessment
60105	Each failed logon	T1078 Valid Accounts	Broad parent tag; a failed logon on its own does not show valid account use
60122	Each 4625 failure	T1531 Account Access Removal	Does not fit this evidence; no account was locked or removed
60204	8 failures from one source within 240s	T1110 Brute Force	Agrees with this report at technique level. This evidence met it: 8 in 226s from 127.0.0.1

This is the most important professional lesson of the day. Rule-level ATT&CK tags are written once by the vendor to cover every situation in which a rule might fire, so they are often broader than, or different from, what a specific incident actually shows. Only the correlation rule, 60204, describes the pattern; the single-event rules do not. An analyst must never copy a tool's tag into a report without checking it against the evidence. Here, Wazuh's correlation rule and the evidence agree on T1110, and the evidence supports going one level more specific, to T1110.001, which no Wazuh rule does on its own.

7. Detection and Mitigation Coverage

7.1 Detection

MITRE's detection strategy for T1110.001 is DET0551, Password Guessing via Multi-Source Authentication Failure Correlation. Its Windows analytic, AN1521, is a series of authentication failures (Event ID 4625) targeting similar accounts. The evidence in this case is precisely that: eight 4625 events against one account. In a live deployment, Wazuh rule 60204 is the mechanism that would implement this analytic.

7.2 Mitigations

MITRE lists four mitigations for T1110.001. Three are directly relevant to this lab:

Mitigation	What it does	Status in this lab
M1036 Account Use Policies	Account lockout after repeated failures	In place: lockout threshold 10, duration 10 minutes (Figure 4)
M1032 Multi-factor Authentication	A second factor, so a guessed password alone is not enough	Not in place for local logon; recommended
M1027 Password Policies	Long, complex passwords that are hard to guess	Minimum password length is 0 (Figure 4); recommended to set one

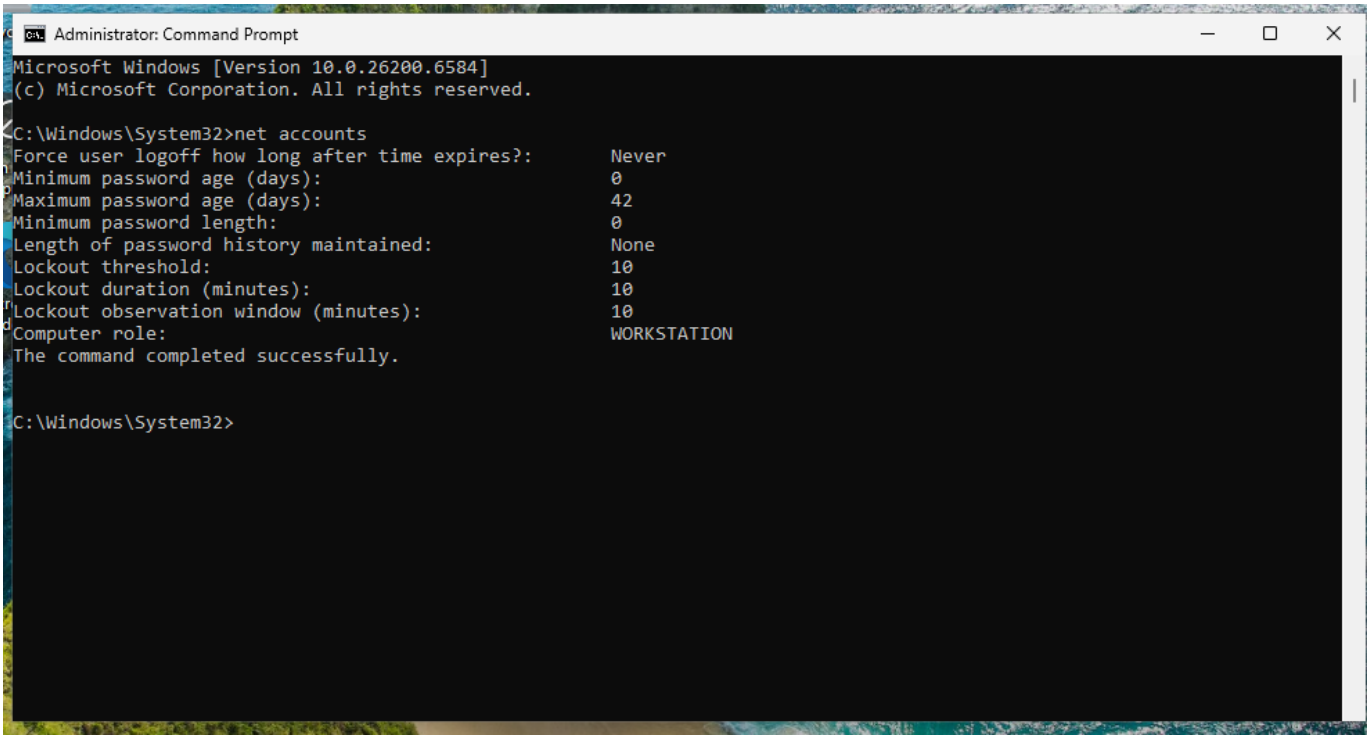


Figure 4. net accounts output on the lab VM (case file SS01).

What this screenshot shows:

- Lockout threshold 10, duration 10 minutes, observation window 10 minutes: M1036 is in place. It would have locked the account on the tenth failure; the test stopped at eight.
- Minimum password length 0: the machine enforces no minimum length, a gap against M1027 Password Policies. A real environment should set a minimum length.
- Maximum password age 42 days and password history None are also visible: password reuse is not prevented.

The lockout threshold (10) sits above Wazuh's detection threshold (8). That ordering is deliberate good practice: the SOC is alerted at 8 failures, before the account is locked at 10, giving an analyst the chance to act before legitimate access is lost.

8. Supporting Evidence Record

Every element of the mapping traces back to a file in the sealed Day 26 case:

Mapping element	Supporting evidence	Case file
TA0006 / T1110: repeated attempts	8 x Event ID 4625, 13:07:33 to 13:11:19	02_Logs_Raw\Security_INC_window.evtx
T1110.001: one account	All 8 failures target CyberAmy	03_Logs_Parsed\INC_window_parsed.csv
Valid user name targeted	SubStatus 0xC000006A	03_Logs_Parsed\INC_window_parsed.csv
Single source, online attempts	Logon Type 2, IP 127.0.0.1	03_Logs_Parsed\INC_window_parsed.csv
Outcome: owner's own logon	2 linked 4624 events at 13:12:10	01_Screenshots\SS06; SS03-SS04
M1036 in place	Lockout threshold 10	04_Endpoint_Info\lockout_policy.txt; SS01
Integrity of all of the above	SHA-256 of every evidence file	00_Case_Notes\hash_manifest.csv

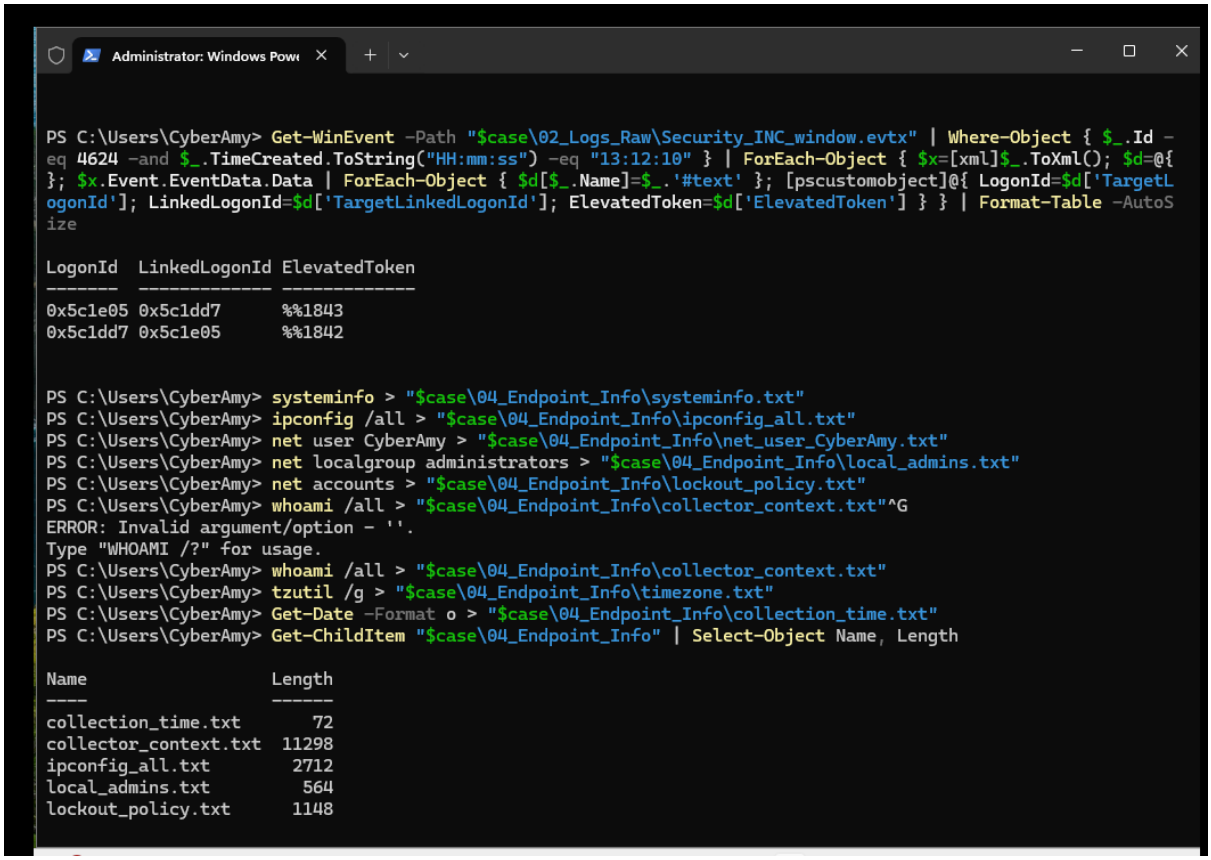


Figure 5. The two linked successful logon sessions at 13:12:10 (case file SS06).

What this screenshot shows:

- Two 4624 sessions, 0x5c1e05 and 0x5c1dd7, each list the other as their linked logon: one elevated (%%1842) and one not (%%1843). This is the UAC split token created when an administrator logs on.
- This matters for mapping because it establishes that the success was a single, ordinary logon by the account owner. That is why T1078 Valid Accounts is not added to the mapping.

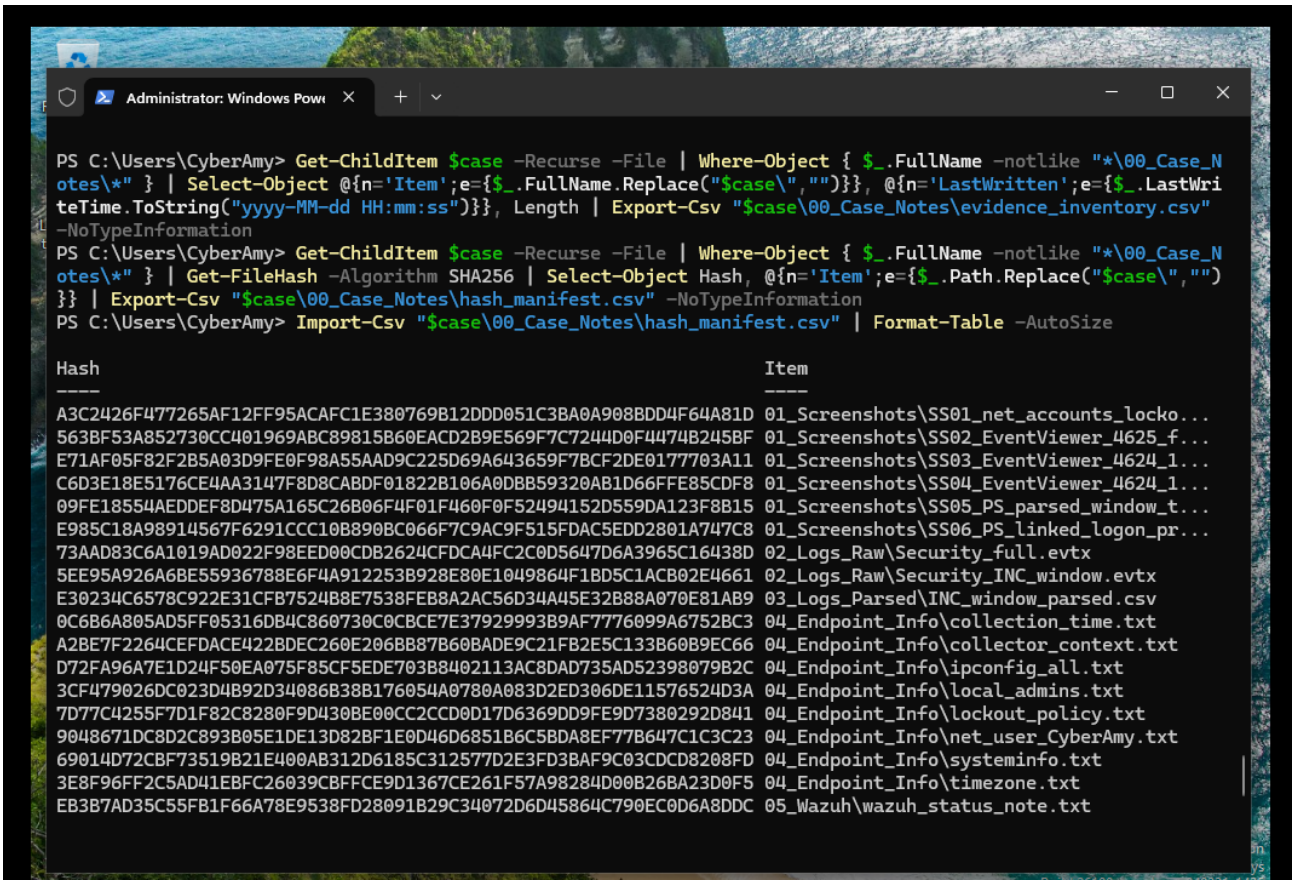


Figure 6. The Day 26 hash manifest sealing all 18 evidence files.

What this screenshot shows:

- Each row is a SHA-256 fingerprint of one evidence file, recorded when the case was sealed in Day 26.
- Because every file used in this mapping is covered by the manifest, anyone can re-hash the files and confirm the evidence behind this mapping has not changed since collection.

9. Mapping Summary

Behavior	8 failed interactive logons against one account in 226 seconds, followed by a successful logon
Tactic	Credential Access (TA0006)
Technique	Brute Force (T1110)
Sub-technique	Password Guessing (T1110.001)
Rejected	T1110.002, T1110.003, T1110.004, T1078, T1531 (Section 5.4)
MITRE detection	DET0551 / AN1521: series of Event ID 4625 failures
Wazuh rule	60204, level 10, tagged T1110; conditions met by this evidence
Mitigations	M1036 in place; M1032 and M1027 recommended
Evidence	Case INC-20260929-001, hash-sealed
Verdict	Benign true positive: authorized self-test by the account owner

10. Conclusion

The repeated authentication failures from Day 25 map to Credential Access (TA0006), Brute Force (T1110), Password Guessing (T1110.001). The mapping is driven by the evidence rather than by assumption: one account, a valid user name, a single source, and eight online attempts in 226 seconds. Each alternative sub-technique was rejected for a specific, evidence-based reason.

Checking Wazuh's own ATT&CK tags showed that tool tags must be verified, not copied: only the correlation rule, 60204, agrees with the evidence, and the evidence supports a more specific mapping than Wazuh provides. Mapping the behavior also exposed a real hardening gap in the lab, the absence of a minimum password length, which is exactly the kind of practical output a mapping exercise should produce.

References

- MITRE ATT&CK: T1110 Brute Force (version 2.8, last modified 12 May 2026), attack.mitre.org/techniques/T1110/
- MITRE ATT&CK: T1110.001 Password Guessing (version 1.7, last modified 12 May 2026), including DET0551 / AN1521 and mitigations M1036, M1032, M1027, M1051; created 11 February 2020.
- MITRE ATT&CK: T1110.002 Password Cracking; T1110.004 Credential Stuffing.
- MITRE ATT&CK: T1110.003 Password Spraying; T1531 Account Access Removal.
- Wazuh ruleset: 0580-win-security_rules.xml (rules 60105, 60122, 60204).
- Day 25 and Day 26 reports, case INC-20260929-001.